PROJECT TECH DOC

LLM-Augmented SAST Triage Platform

Tóm tắt kỹ thuật Sprint 1 và Sprint 2

Phiên bản: 0.1.0

Ngày cập nhật: 15/08/2026

Phạm vi: Python repository; Semgrep, Gitleaks, FastAPI authorization

Trạng thái: Technical summary - phục vụ trình bày và bàn giao

Tóm tắt: Hệ thống nhận một Python repository, chạy scanner, chuẩn hóa finding, lấy ngữ cảnh đã làm sạch, gọi LLM để đề xuất triage, áp dụng policy bảo thủ và xuất báo cáo có thể audit. Sprint 2 bổ sung một detector logic-bug chuyên biệt cho FastAPI thiếu function-level authorization.

1. Tổng quan hệ thống

Mục tiêu của dự án là hỗ trợ security reviewer phân loại finding mà không để LLM tự động xóa hoặc suppress cảnh báo. Mọi finding đều được giữ trong báo cáo, kể cả khi context thiếu hoặc provider lỗi.

```
Repository -> Semgrep + Gitleaks -> NormalizedFinding -> Safe Context
-> TriageProvider -> PolicyDecision -> report.json + report.md
```

Phần	Sprint 1	Sprint 2
Mục tiêu	Xây pipeline scan và triage an toàn end-to-end.	Thêm detector logic-bug authorization cho FastAPI.
Nguồn finding	Semgrep và Gitleaks.	Module 2 native AST/index, sau đó nhập pipeline chung.
Đầu ra	NormalizedFinding, verdict, policy action, JSON/Markdown.	Finding CWE-862 cùng verdict/policy/report hiện có.
Trạng thái	Luồng sản phẩm chính đã hoạt động.	Detector chuyên biệt đã triển khai; chưa phải logic-bug tổng quát.

2. Sprint 1 - Nền tảng scan và triage

Sprint 1 xây dựng pipeline sản phẩm chính. Hai chế độ CLI triage và scan-and-triage khác nhau ở cách lấy scanner artifact nhưng cùng đi qua một pipeline triage duy nhất.

2.1 Các phần đã triển khai

- **Scanner và parser:** chạy Semgrep/Gitleaks, đọc JSON và chuẩn hóa về NormalizedFinding.
- **Bảo vệ bí mật:** Gitleaks redact sớm; raw secret không đi vào model, log, prompt hoặc báo cáo.
- **Safe Context:** chặn path traversal, absolute/symlink escape, file quá lớn và sanitize credential trong source gần finding.
- **Domain model:** sáu model public tách biệt, frozen bằng Pydantic v2 và validate ở component boundary.
- **LLM triage:** hỗ trợ fake, Ollama và Qwen3-14B-AWQ trên Modal; output bắt buộc qua schema validation.
- **Policy bảo thủ:** LLM chỉ đề xuất verdict; policy quyết định LIKELY_TP, FP_CANDIDATE, MANUAL_REVIEW hoặc TRIAGE_ERROR.
- **Báo cáo và audit:** xuất report.json, report.md, run-metadata.json, checkpoint và scanner artifacts.

2.2 Bất biến bảo mật chính

- Raw source chỉ tồn tại trong local scope của SafeContextService.
- Finding từ repository A không được triage bằng context của repository B.
- Không lưu raw prompt, raw response, traceback, secret hoặc đường dẫn repository tuyệt đối trong report.
- Lỗi trên một finding không được làm mất các finding còn lại.

2.3 Chạy Sprint 1

Điều kiện: .venv đã active và PowerShell đang ở D:\Code\target-repos.

```
python -m sast_triage TEN_REPO
```

Lệnh rút gọn dùng provider real trên Modal và tự tạo output có timestamp trong D:\Code\triage-runs. Dùng provider fake khi chỉ cần kiểm tra scanner, pipeline và report offline.

3. Sprint 2 - FastAPI authorization logic detector

Phạm vi thực tế: Sprint 2 hiện phát hiện một lớp logic-bug: endpoint FastAPI nhạy cảm thiếu function-level authorization (CWE-862). Đây chưa phải detector tổng quát cho năm lớp logic bug.

3.1 Cách detector hoạt động

- Dùng Python AST và bounded repository index để nhận diện FastAPI, APIRouter, route decorator, Depends, Security và include_router.
- Đánh giá route có nhạy cảm hay không dựa trên method, resource identifier, route semantics và control đã biết.
- Phân biệt authentication với authorization; chỉ có get_current_user không đồng nghĩa người dùng có quyền thao tác tài nguyên.
- Phân loại nội bộ thành PROTECTED, MISSING_AUTHZ_CANDIDATE hoặc UNKNOWN.
- Candidate hoàn chỉnh trở thành finding module2.fastapi.missing-function-authz và đi qua Safe Context, LLM, policy, reporter của Sprint 1.

3.2 Quy tắc giảm false positive

- Route public như health, login, docs và metrics không bị báo nếu không có dấu hiệu nhạy cảm khác.
- Router-level dependency và include_router dependency được kế thừa khi đánh giá authorization.
- Dynamic middleware hoặc context không đủ được chuyển thành UNKNOWN thay vì tự kết luận thiếu authorization.
- Không tự động suppress finding; reviewer vẫn quyết định cuối cùng.

3.3 Chạy Sprint 2

Điều kiện: .venv đã active, Semgrep/Gitleaks có trong PATH và PowerShell đang ở D:\Code\target-repos. Đổi cả hai chỗ TEN_REPO thành tên thư mục repository FastAPI.

```
python -m sast_triage scan-and-triage --repository .\TEN_REPO --output-dir ..\triage-runs\TEN_REPO-sprint2 --analysis-backend native --module2 --logic-detector fastapi-missing-authz --provider fake
```

Dùng LLM thật trên Modal bằng cách đổi --provider fake thành --provider real.

4. Kết quả và trạng thái hiện tại

4.1 Qualification detector Sprint 2

Bộ qualification hiện tại có 80 case (35 natural RealVuln và 45 controlled mutation), cân bằng 40 positive/40 negative. Kết quả ghi nhận TP=40, FP=0, FN=0, TN=39 và UNKNOWN=1; held-out có 38 case với TP=20, FP=0, FN=0, TN=18.

> **Cảnh báo diễn giải:** Các chỉ số trên chỉ đúng với dataset qualification hiện tại. Governance gate vẫn chờ independent two-reviewer audit; không dùng kết quả fixture hoặc mutation để tuyên bố chất lượng tổng quát ngoài dataset.

4.2 Kiểm thử và hồi quy

- Ba run detector deterministic cho kết quả giống nhau từng byte.
- Paired offline regression: 20 repository x 3 lần x 2 nhánh, tổng 120 run; không ghi nhận pipeline error trong báo cáo qualification.
- Security suite: 175 passed, 2 skipped; full suite: 488 passed, 2 skipped theo báo cáo hiện tại.

4.3 Vấn đề vận hành đã quan sát

Run gần nhất trên Sequential-Recommender tìm được 13 finding (1 Semgrep và 12 Module 2), nhưng Modal client ngắt kết nối trong lúc vLLM/FlashInfer warm-up. Vì vậy 13 finding được giữ lại với TRIAGE_ERROR; scanner và detector vẫn hoàn tất, còn LLM chưa tạo verdict.

5. Đầu ra và cách đọc

- **report.md:** báo cáo chính để reviewer và mentor đọc.
- **report.json:** dữ liệu finding, decision, policy và lỗi xử lý có cấu trúc.
- **run-metadata.json:** commit, scanner version/config, provider, model và repository binding.
- **scanner-artifacts/:** JSON gốc từ Semgrep/Gitleaks; có thể nhạy cảm và không nên gửi ra ngoài tùy tiện.

6. Giới hạn và bước tiếp theo

- Chưa phát hiện tổng quát IDOR/BOLA, mass assignment, race condition/TOCTOU, cross-service authorization hoặc business workflow bypass.
- Chưa có auto-fix, auto-suppression, risk scoring đã hiệu chỉnh, dashboard hoặc CI/CD gate.
- Cần hoàn tất independent reviewer audit và real-LLM regression trước khi công bố quality claim rộng hơn.
- Nên cải thiện Modal provider theo hướng fail-fast, retry có giới hạn và giữ checkpoint khi remote session bị ngắt.

7. Tài liệu nguồn nội bộ

- docs/sprint-1-scope.md - phạm vi và iteration Sprint 1.
- docs/sprint-2-scope.md - detector FastAPI authorization và qualification status.
- docs/architecture.md - pipeline, component boundary và repository-artifact binding.
- docs/cli-usage.md - cài đặt, câu lệnh chạy, output và troubleshooting.
- docs/security-policy.md - quy tắc xử lý source, secret, prompt và report.